HSLU

SW06 Deivce Tracking

Privatheit und Technologie

Dozent: Dr. Radwan Eskhita

FS26

HSLU

Agenda

1

Gesicht und Tone Erkennung

2

RFID und NFC Technologien

Funktionsweise, Anwendungen und Sicherheitsaspekte von Radio-Frequency Identification

3

IoT und Privacy

Datenschutzherausforderungen im Internet der Dinge

4

E-Passport Sicherheit

Biometrische Daten und kryptographische Schutzverfahren

Technik der Gesichtserkennung

Gesichtserkennung basiert auf der systematischen Analyse sichtbarer Merkmale im Bereich des frontalen Kopfes. Die Technologie erfasst geometrische Anordnungen und Textureigenschaften der Gesichtsoberfläche, um eindeutige biometrische Profile zu erstellen.

01

Gesichtsfindung

Das System lokalisiert zunächst Gesichter in Bildern oder Videostreams und grenzt den relevanten Bereich ab.

02

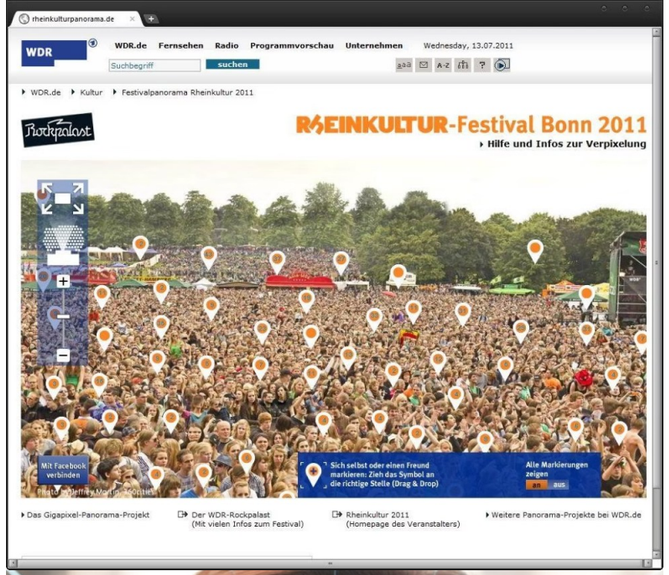
Referenzpunktdetektion

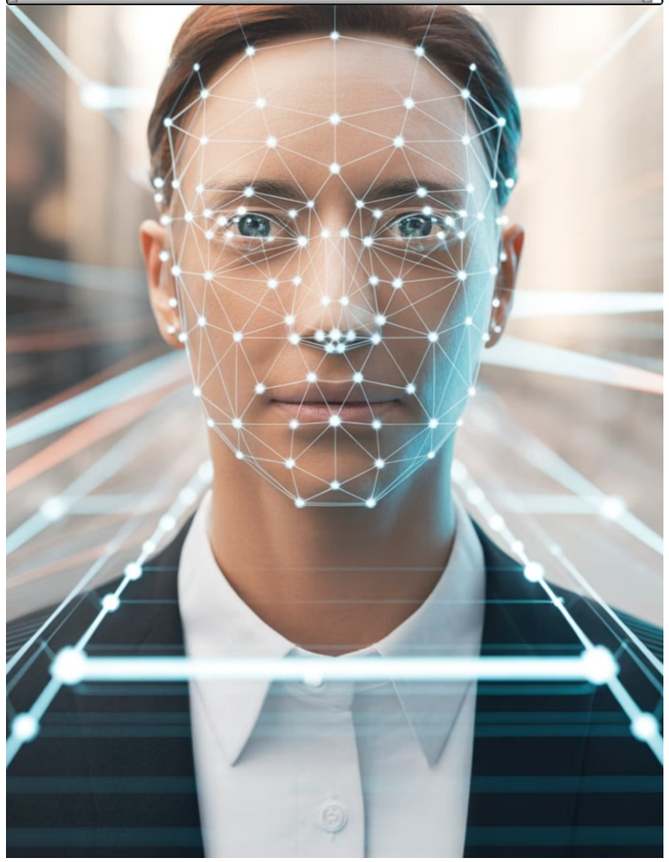
Algorithmen identifizieren markante Gesichtspunkte wie Augen, Nase, Mundwinkel und Kieferkontur.

03

Gesichtserkennung

Die finale Analyse umfasst Identifikation (Wer ist die Person?), Verifikation (Ist es Person X?) und Attributanalyse (Alter, Geschlecht, Emotionen).





Gesichtserkennung: Definition und Funktionsweise

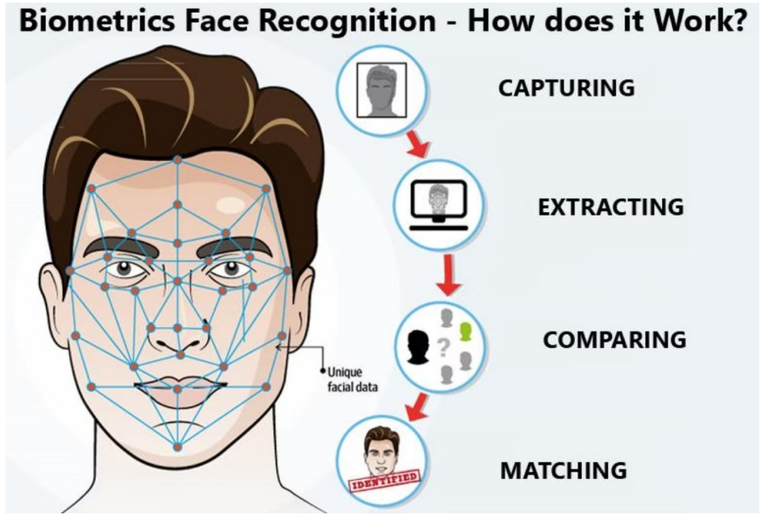


Technologiedefinition

Ein Gesichtserkennungssystem ist eine biometrische Technologie, die menschliche Gesichter in digitalen Bildern oder Videostreams identifiziert und mit einer Referenzdatenbank abgleicht.

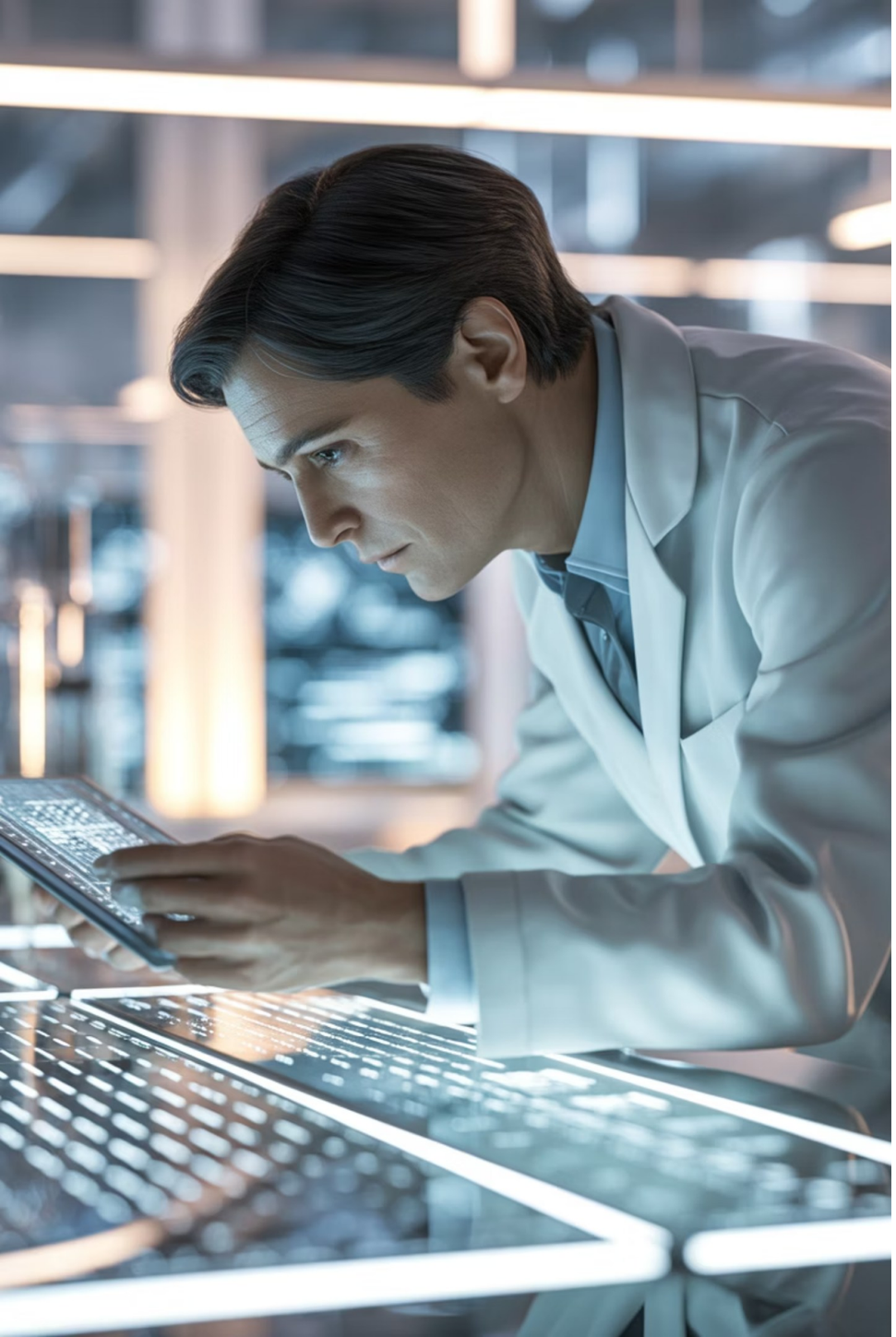
Authentifizierungsprozess

Das System wird primär zur Benutzerauthentifizierung eingesetzt. Es erfasst, misst und analysiert einzigartige Gesichtsmerkmale, um die Identität einer Person zu verifizieren.



„Die Gesichtserkennung transformiert biometrische Merkmale in digitale Signaturen, die mit hoher Präzision Personen identifizieren können."

Quelle: Parul Institute of Engineering and Technology, PARUL UNIVERSITY



Local Binary Pattern (LBP)

Local Binary Pattern (LBP) ist einer der leistungsfähigsten Texturbeschreiber in der Bildverarbeitung und findet breite Anwendung in verschiedenen Computer-Vision-Aufgaben, insbesondere bei der Gesichtserkennung.

1. **Regionale Segmentierung**
   Das Gesichtsbild wird in lokale Regionen unterteilt, wobei jede Region unabhängig analysiert wird.
2. **Texturextraktion**
   Aus jeder Region werden spezifische Texturbeschreibungen extrahiert, die charakteristische Muster erfassen.
3. **Globale Beschreibung**
   Die regionalen Beschreibungen werden zu einer globalen Gesichtsbeschreibung verknüpft.



Technischer Vorteil: LBP ist robust gegenüber Beleuchtungsänderungen und rechnerisch effizient, was Echtzeit-Anwendungen ermöglicht.

https://faceshapedetector.ai/

HSLU

Dynamische Emotionserkennung

4D-Videosequenzanalyse

Die dynamische Gesichtserkennung aus 4D-Videosequenzen repräsentiert die nächste Generation der Emotionsanalyse. Diese Technologie erfasst nicht nur statische Gesichtsmerkmale, sondern analysiert zeitliche Veränderungen und Bewegungsmuster.

Zeitliche Dimension

Erfassung von Mikroexpressionen und Bewegungsverläufen über Zeit hinweg

Räumliche Tiefe

3D-Gesichtsgeometrie für präzisere Merkmalserkennung unabhängig vom Blickwinkel

Emotionale Dynamik

Erkennung subtiler Übergänge zwischen emotionalen Zuständen

> 4D-Emotionserkennung ermöglicht die Analyse authentischer, natürlicher Ausdrücke in realen Interaktionssituationen.



Praktische Anwendungen

Clearview.ai (Januar 2020)
Datenbasis: 3 Milliarden Porträtfotos aus dem
Realer Fall: Restaurant-Identifikation

Milliardär John Catsimatidis nutzte Clearview.ai, um in einem Restaurant das Date seiner Tochter zu identifizieren. Sein Kommentar: „Ich wollte sicher sein, dass er kein Scharlatan ist."

PimEyes.com (Juli 2020)
Datenbasis: 900 Millionen Porträtfotos

Diese Suchmaschine ermöglicht es, durch Hochladen eines Fotos alle öffentlich verfügbaren Bilder einer Person zu finden. Durch die angezeigten Websites lassen sich häufig Namen, Beruf und weitere persönliche Informationen herausfinden.

FBI und Führerschein-Datenbanken

Das FBI nutzt Zugang zu staatlichen Führerschein-Datenbanken für Gesichtserkennungsabfragen, oft ohne explizite Zustimmung der Betroffenen. Dies wirft erhebliche rechtliche und ethische Fragen auf.



The billionaire John Catsimatidis used Clearview to surveil shoppers at a grocery store he owns, and to identify a man he saw on a date with his daughter. Krista Schlueter for The New

Datenschutzbedenken Schweiz

Der EDÖB (Eidgenössischer Datenschutz- und Öffentlichkeitsbeauftragter) warnte wiederholt vor drohenden Persönlichkeitsverletzungen durch ungefragte Beschaffung von Gesichtsbildern im Internet.

HSLU

Reverse Image Search: Selbsttest

Mit Reverse Image Search Tools können Sie selbst überprüfen, wo Ihre Bilder im Internet auftauchen.

Small SEO Tools

smallseotools.com/reverse-image-search

Kostenloses Tool für erste Tests mit einfacher Benutzeroberfläche

PimEyes

pimeyes.com/en

Spezialisierte Gesichtssuchmaschine mit umfangreicher Datenbank

Praktische Übung:

1. Wählen Sie ein Foto von sich selbst
2. Laden Sie es bei einem der obigen Services hoch
3. Analysieren Sie die Ergebnisse: Wo taucht Ihr Bild auf?
4. Dokumentieren Sie Ihre Erkenntnisse

Reflexionsfragen: Waren Sie überrascht von den Ergebnissen? Welche Websites haben Sie identifiziert? Wie fühlen Sie sich damit?

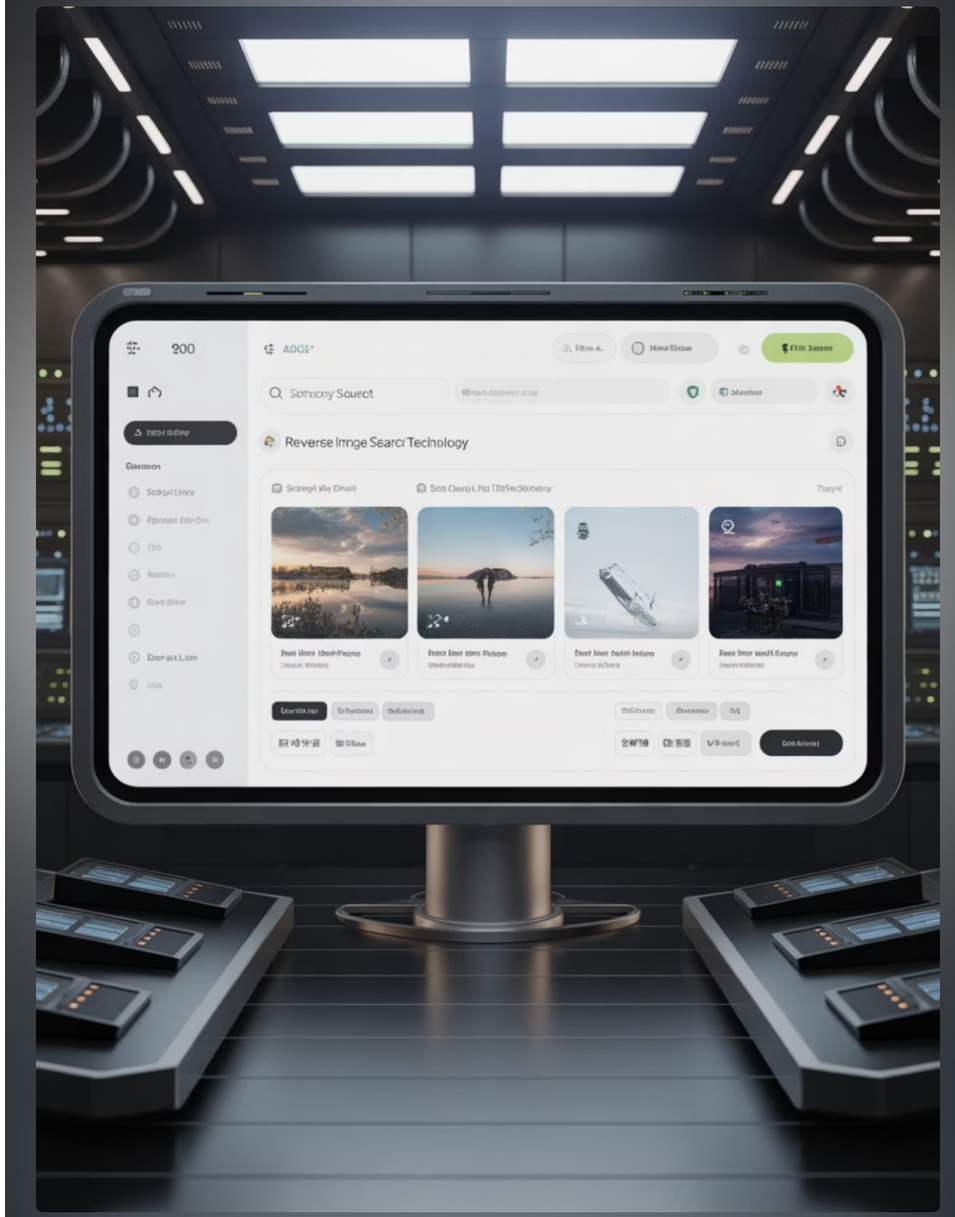


Image Cloaking

Schutz der Privatsphäre

Image Cloaking bezeichnet Techniken, die Gesichter in Fotos für automatisierte Erkennungssysteme unkenntlich machen, während sie für menschliche Betrachter normal aussehen.

Fawkes: Adversarial Cloaking System

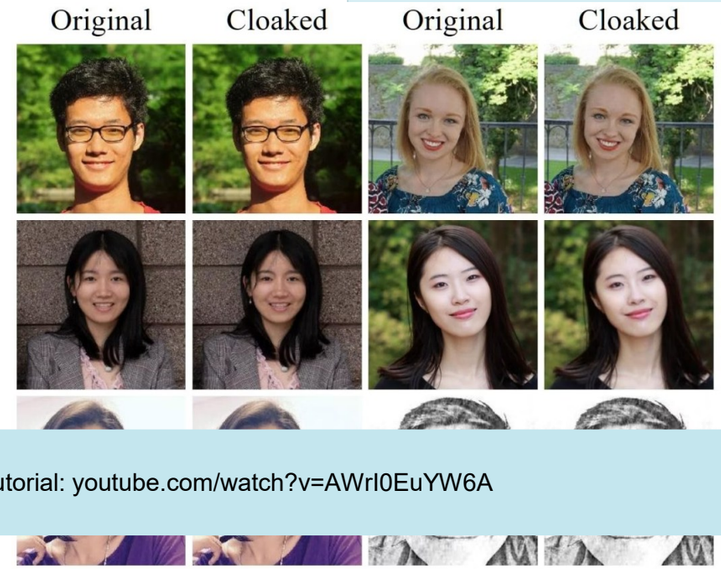
Fawkes ist ein innovatives Tool, das Fotos mit minimalen, für das menschliche Auge unsichtbaren Pixeländerungen versieht. Diese Technik wird als "Image Cloaking" bezeichnet und funktioniert durch gezieltes "Vergiften" von Machine-Learning-Modellen.

Unsichtbare Modifikation
Fawkes fügt pixelgenaue Änderungen hinzu, die visuell nicht wahrnehmbar sind, aber Algorithmen täuschen.

Model Poisoning
Wenn gecloakte Bilder zum Training verwendet werden, lernt das Modell eine verzerrte Repräsentation Ihres Gesichts.

Schutzmechanismus
Bei späteren Identifizierungsversuchen mit ungecloakten Bildern versagt das System bei der Erkennung.

Face Recognition API	Protection Success Rate		
	Without protection	Protected by normal cloak	Protected by robust cloak
Microsoft Azure Face API	0%	100%	100%
Amazon Rekognition Face Verification	0%	34%	100%
Face++ Face Search API	0%	0%	100%



Selbsttest: Besuchen Sie sandlab.cs.uchicago.edu/fawkes und testen Sie Fawkes mit eigenen Fotos. Video-Tutorial: youtube.com/watch?v=AWrI0EuYW6A

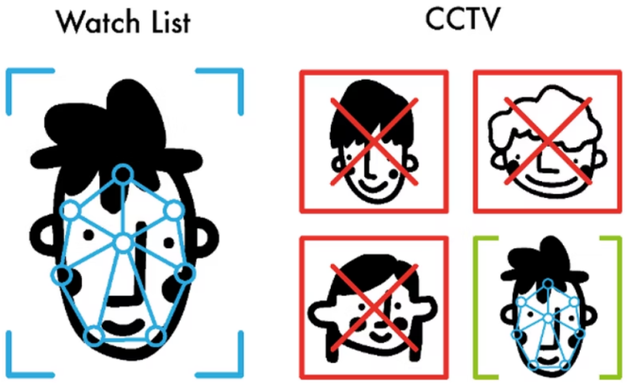
Bilddatenbanken und Watchlists

Funktionsprinzip

Bilddatenbanken nehmen die Form von Watchlists an – strukturierte Sammlungen von Bildern und biometrischen Templates von Personen, nach denen das System sucht.

Erkennungsprozess

1. Eingehendes Bild wird analysiert und Template erstellt
2. Template wird mit allen Einträgen der Watchlist verglichen
3. Ähnlichkeitswerte werden für jeden Eintrag berechnet
4. Bei Überschreiten des Schwellwerts wird Alert generiert
5. Menschlicher Operator verifiziert die Übereinstimmung



Jude Webster © 2023

Art. 6(1)(e) Data Protection Act 2018 – „Aufgabe im öffentlichen Interesse“

Kritische Faktoren

- **Schwellwert:** Balance zwischen False Positives und False Negatives
- **Watchlist-Grösse:** Beeinflusst Performance und Genauigkeit
- **Bildqualität:** Entscheidend für Template-Qualität

HSLU

Drei zentrale Designfragen

Bei der Implementierung eines Gesichtserkennungssystems müssen fundamentale praktische Fragen beantwortet werden, die sowohl technische als auch rechtliche Implikationen haben:

1 **Watchlist-Kriterien**

Wann kann jemand zur Watchlist hinzugefügt werden?

Diese Frage definiert, wen das System suchen darf. Kriterien müssen rechtlich fundiert, präzise definiert und dokumentiert sein. Sie bestimmen die Legitimität des gesamten Systems.

2 **Watchlist-Grösse**

Wie viele Personen sollten gleichzeitig gesucht werden?

Die Anzahl der Einträge beeinflusst Performance, Genauigkeit und Ressourcenbedarf. Grössere Watchlists erhöhen die Wahrscheinlichkeit falscher Treffer und erfordern mehr Rechenleistung.

3 **Datenfreigabe**

Was geschieht bei einer Übereinstimmung?

Prozesse für Datenweitergabe, Speicherung, Benachrichtigung und Löschung müssen definiert werden. Dies betrifft sowohl technische Workflows als auch rechtliche Compliance.

Wichtig: Diese Fragen begrenzen, wie ein System rechtlich operieren kann, da Gesichtserkennung inhärent biometrische Daten verarbeitet und somit unter besondere Datenschutzbestimmungen fällt.

HSLU

Watchlist-Kriterien: Private Akteure

Für private Organisationen gelten besonders strenge Anforderungen bei der Nutzung von Gesichtserkennungstechnologie.
Die rechtliche Grundlage basiert primär auf Datenschutzgesetzen wie der DSGVO in Europa.

Preventing or detecting unlawful acts

10 (1) This condition is met if the processing—

(a) is necessary for the purposes of the prevention or detection of an unlawful act,

(b) must be carried out without the consent of the data subject so as not to prejudice those purposes, and

(c) is necessary for reasons of substantial public interest.

1

Rechtsgrundlage erforderlich

Private Unternehmen benötigen eine klare rechtliche Basis für die Verarbeitung biometrischer Daten. In der Regel ist explizite Einwilligung erforderlich, es sei denn, es besteht ein überwiegendes berechtigtes Interesse.

2

Zweckbindung

Die Verwendung muss für einen spezifischen, legitimen Zweck erfolgen (z.B. Zugangskontrolle, Diebstahlprävention). Eine spätere Zweckänderung ist nur unter strengen Bedingungen zulässig.

3

Verhältnismässigkeit

Die Massnahme muss angemessen sein. Alternative, weniger invasive Methoden müssen geprüft werden. Der Nutzen muss die Eingriffe in die Privatsphäre überwiegen.

This last six months has really tested us. It's good to know we are part of the community. We also know that this pandemic has made it easier for thieves to steal from our stores. We were fortunate that in 2019 we made the decision to install another new technology, in the footsteps of our great grandfather, using facial recognition to help us recognise habitual thieves and troublemakers that frequent our store in Southampton.

The purpose of our targeted use of facial recognition is to identify when a known offender, including individuals who have been evidenced as an offender or those who have been excluded, enter one of our stores. This gives our colleagues time to decide on any action they need to take, for example, asking

Private Akteure tragen die Beweislast für die Rechtmässigkeit ihrer Datenverarbeitung. Dokumentation und Transparenz sind essentiell.

Watchlist-Grösse in der Praxis

Deployment Location	Date	Duration of Deployment	LFR Purpose Reference	Watchlist Size
Camden	06/04/23	5h03m	1,2,3,4	9764
Camden	14/04/23	5h03m	1,2,3,4	9744
Islington	20/04/23	4h50m	1,2,3,4	9816
Westminster Bridge Street	06/05/23	8h09m	1,2,3,4	10451
Westminster, Savoy Place	06/05/23	8h0m	1,2,3,4	10451
Westminster, Piccadilly	06/05/23	8h34m	1,2,3,4	10451
Westminster, The Mall	17/06/23	5h40	1,2,3,4	10412
Westminster, Birdcage Walk	17/06/23	4h45	1,2,3,4	10412
Westminster	11/08/23	3h17m	1,2,3,4	12056
Westminster	18/08/23	8h34m	1,2,3,4	11876
Camden	08/09/23	4h12m	1,2,3,4	11916
Westminster	09/09/23	2h52m	1,2,3,4	11982
Islington	24/09/23	5h30m	1,2,3,4	11894
Haringey, High Rd	06/11/23	5h45m	1,2,3,4	12187
Haringey, Love Lane	06/11/23	5h57m	1,2,3,4	12187
Westminster	09/11/23	4h41m	1,2,3,4	12168
Westminster	16/11/23	0h33m	1,2,3,4	11497
Croydon, George St	07/12/23	4h30m	1,2,3,4	12165
Croydon, Northend	07/12/23	3h45m	1,2,3,4	12165

Polizeilicher Einsatz

Bei polizeilichen Anwendungen variieren Watchlist-Grössen erheblich je nach Einsatzszenario:

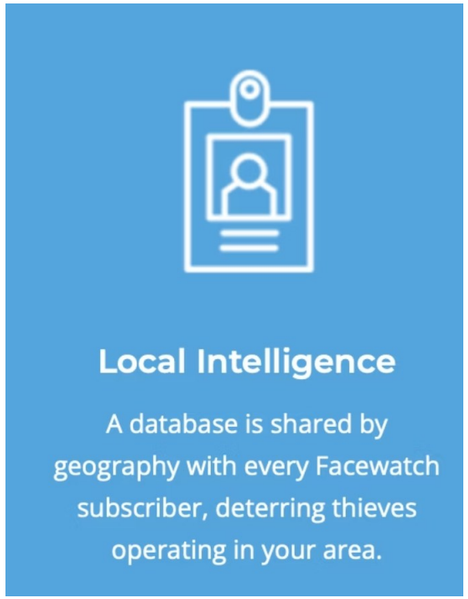
- **Veranstaltungsschutz:** 50-500 Personen (bekannte Störer, Gesuchte)
- **Fahndungen:** 100-2.000 Personen (regionale bis nationale Listen)
- **Grenzkontrollen:** Bis zu 10.000+ Personen (internationale Fahndungslisten)

Privater Sektor

Im privaten Bereich operieren Watchlists typischerweise geografisch begrenzt:

- **Einzelhandel:** 20-200 Personen pro Filiale (bekannte Ladendiebe)
- **Shopping-Center:** 100-500 Personen (regional koordinierte Listen)
- **Eventlocations:** 50-300 Personen (Hausverbote, Sicherheitsrisiken)

Grössere Watchlists erhöhen exponentiell die Wahrscheinlichkeit falscher Positiver und erfordern mehr Rechenkapazität.



Regulatorische Rahmenbedingungen

Die regulatorische Landschaft für Gesichtserkennung ist komplex und vielschichtig. Verschiedene Regelwerke greifen ineinander und schaffen einen mehrschichtigen Rechtsrahmen.



Home Office secretly backs facial recognition technology to curb shoplifting

Covert government strategy to install electronic surveillance in shops raises issues around bias and data, and contrasts sharply with the EU ban to keep AI out of public spaces

Grundrechte
EU-Grundrechtecharta, Recht auf Privatsphäre

Datenschutz
DSGVO, nationale Datenschutzgesetze

KI-Regulierung
EU AI Act, Hochrisiko-Klassifizierung

Strafprozessrecht
Polizeigesetze, Ermittlungsbefugnisse

Antidiskriminierung
Gleichbehandlungsgesetze, Bias-Prävention

HSLU

Tone Erkennung



HSLU

Spracherkennung: Amazon Echo

Intelligente Sprachassistenten



Drücken Sie die Mikrofon-aus-Taste, um die Mikrofone zu deaktivieren

Sprachgesteuerte IoT-Geräte und intelligente Hausassistenten wie Amazons Alexa haben in den letzten Jahren enorme Beliebtheit in Privathaushalten erlangt. Diese Geräte versprechen Komfort durch natürliche Sprachinteraktion.

Datenschutzbedenken

Die Technologie wirft jedoch beispiellose Sicherheits- und Datenschutzfragen auf:

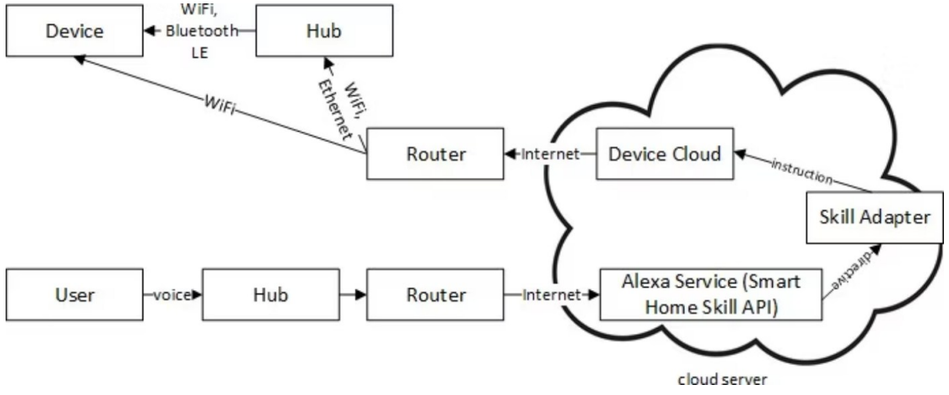
- Permanente Audioerfassung im privaten Raum
- Übertragung persönlicher und sensibler Daten
- Unklare Datenverarbeitungsprozesse in der Cloud
- Potenzial für Missbrauch durch Dritte
- Fehlende Transparenz über Datennutzung

> Die Bequemlichkeit sprachgesteuerter Geräte steht in direktem Spannungsverhältnis zu fundamentalen Datenschutzrechten. Nutzer müssen diesen Trade-off bewusst abwägen.

Funktionsweise Amazon Echo

Das Amazon Echo-Ökosystem basiert auf einer komplexen Architektur aus lokaler Verarbeitung und Cloud-Services. Verständnis dieser Architektur ist essentiell für die Bewertung von Datenschutzrisiken.

1. **Lokales Gerät**
   Kontinuierliche Audioerfassung, lokale Triggerwort-Erkennung ("Alexa"), Audioaufnahme bei Aktivierung
2. **Netzwerkübertragung**
   Verschlüsselte Übertragung der Audioaufnahme zu Amazon Web Services (AWS)
3. **Cloud-Verarbeitung**
   Speech-to-Text-Konvertierung, Natural Language Processing, Intent-Erkennung
4. **Skill-Ausführung**
   Aktivierung entsprechender Alexa Skills (Drittanbieter oder Amazon-eigene Services)
5. **Antwort**
   Text-to-Speech-Generierung, Übertragung zurück zum Gerät, Audio-Ausgabe



HSLU

Werden wir permanent belauscht?

Wissenschaftliche Evidenz und Mythen

Die Frage, ob Smartphones und Smart Speakers uns permanent abhören, beschäftigt viele Nutzer. Die wissenschaftliche Datenlage ist jedoch eindeutig:

Datenvolumen-Argument

Kontinuierliches Streaming würde enorme Datenmengen erzeugen, die im monatlichen Datenvolumen sofort auffallen würden. Messungen zeigen: Dies geschieht **nicht**.

Wissenschaftliche Studien

Forscher konnten in kontrollierten Untersuchungen nicht beweisen, dass beliebte Apps das Mikrofon heimlich aktivieren und auf Schlüsselwörter reagieren.

Anbieter-Statements

Facebook, Google und andere Anbieter verneinen die Abhörpraxis kategorisch. Rechtliche Konsequenzen bei Aufdeckung wären existenzbedrohend.

Regulatorische Aufsicht

Facebook und Google werden inzwischen genauer von Politik und Regulierungsbehörden beobachtet. Ein heimlicher Lauschangriff auf Milliarden Menschen wäre ein wirtschaftliches Existenzrisiko.

Quelle: Woher weiss Google, wo ich bin? | ZEIT ONLINE 20.09.2019

Video: youtube.com/watch?v=Wo9arZs21WI

Studie: recon.meddle.mobi/papers/panoptispy18pets.pdf

Praktischer Test: Netzwerkverbindungen

Selbstversuch mit PCAPdroid

Mit der App PCAPdroid können Sie selbst überprüfen, welche Netzwerkverbindungen bei Aktivierung eines Sprachassistenten entstehen. Dies ist ein praktischer Weg, Transparenz über Datenflüsse zu gewinnen.

1 **Installation**

Laden Sie PCAPdroid aus dem Google Play Store herunter und installieren Sie die App auf Ihrem Android-Gerät.

2 **Aufzeichnung starten**

Öffnen Sie PCAPdroid und starten Sie die Netzwerkaufzeichnung. Die App erstellt ein lokales VPN, um Traffic zu analysieren.

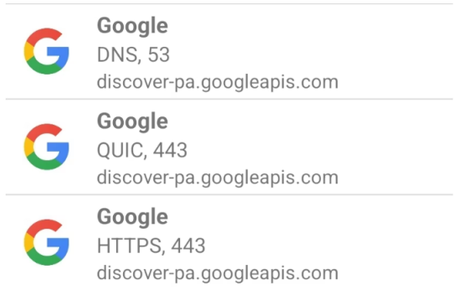
3 **Sprachassistent aktivieren**

Sagen Sie "Hey Google" und beobachten Sie in Echtzeit, welche Verbindungen aufgebaut werden.

4 **Analyse der Ergebnisse**

Untersuchen Sie Ziel-IP-Adressen, übertragene Datenmenge und Zeitpunkte der Verbindungen. Dokumentieren Sie Ihre Beobachtungen.

Beobachtungen: "Hey Google" Aktivierung



Test der permanenten Überwachung

Technische Analyse durch Sicherheitsforscher

Unabhängige Sicherheitsforscher haben verschiedene Methoden angewandt, um zu prüfen, ob Amazon Echo und ähnliche Geräte kontinuierlich Daten senden. Die Ergebnisse sind aufschlussreich.

Testmethodik

- **Physisches Hacken:** Extrem schwierig aufgrund integrierter Sicherheitsmassnahmen
- **Online Shopping by Voice:** Funktionstest legitimer Nutzungsszenarien
- **Man-in-the-Middle-Angriff:** Abfangen und Analyse des Netzwerkverkehrs

Herausforderungen

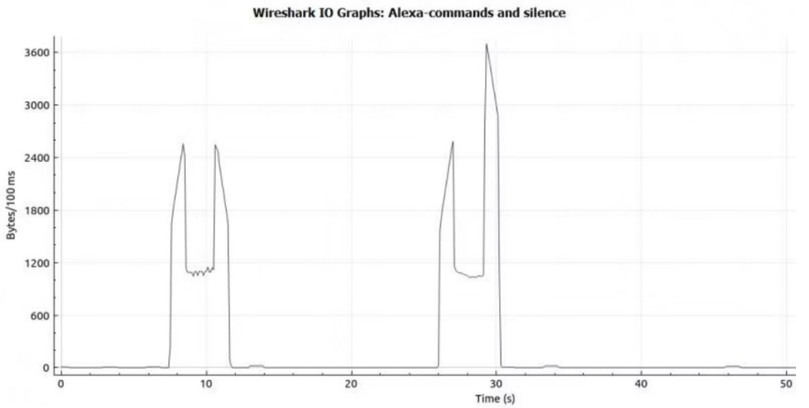
Die Analyse der Echo-Daten stösst auf technische Grenzen:

- **SSL-Verschlüsselung:** End-to-End-Verschlüsselung verhindert Inhaltsanalyse
- **Certificate Pinning:** Zertifikate werden vom Gerät überprüft, MITM-Angriffe erschwert

Messbare Parameter

Trotz Verschlüsselung lässt sich der Datendurchfluss messen:

- Zeitpunkt der Verbindungen
- Übertragene Datenmenge
- Frequenz der Kommunikation
- Ziel-Server und Ports



Fazit der Untersuchung

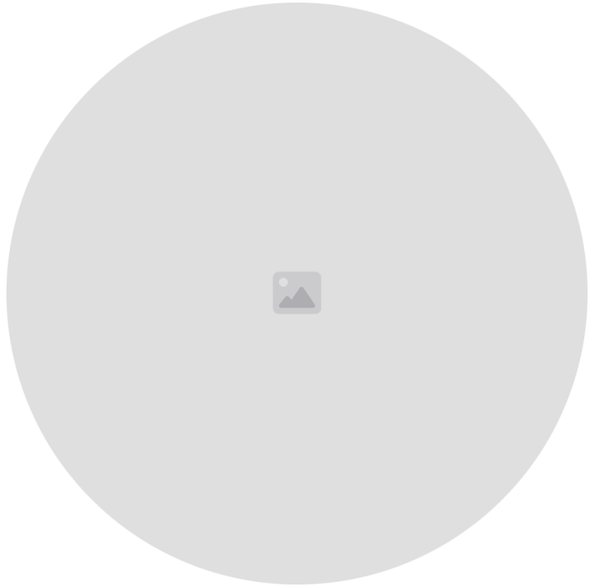
> **Kein Indiz für permanente Überwachung:** Datensendung erfolgt nur bei expliziter Aktivierung durch das Schlüsselwort. Kontinuierliches Streaming wurde nicht beobachtet.

Quelle: iot-tests.org - Careless Whisper

WIPRO-Testszenarien: Einführung

Studentische Forschungsarbeit zur Sprachassistenten-Sicherheit

Im Rahmen einer WIPRO-Projektarbeit führten Elias Gmünder und Andrin Heeb eine systematische Sicherheitsanalyse von Sprachassistenten durch. Ihre Arbeit testet vier führende Systeme gegen bekannte Angriffsvektoren.



Amazon Alexa

Marktführer im Smart-Home-Bereich



Samsung Bixby

Integriert in Samsung-Smartphones



Google Assistant

Android-basiertes System



Apple Siri

iOS-Ökosystem

Testmethodik

Die Studenten entwickelten standardisierte Testprotokolle für vier Angriffskategorien: Hidden Command Attacks, Replay Attacks, Voice Cloning und Triggerwort-Zuverlässigkeit. Jeder Test wurde mehrfach wiederholt, um statistisch valide Ergebnisse zu erzielen.

Die folgenden Slides präsentieren die Kernergebnisse dieser praktischen Sicherheitsanalyse.

Hidden Command Attack

Test versteckter Befehle

Hidden Command Attacks nutzen für Menschen unhörbare oder schwer wahrnehmbare Audiofrequenzen, um Befehle an Sprachassistenten zu übermitteln. Dies könnte Angreifern ermöglichen, Geräte fernzusteuern, ohne dass Nutzer es bemerken.

Testaufbau

Manipulierte Audiodateien mit versteckten Befehlen wurden den vier Sprachassistenten vorgespielt. Die Befehle waren in Ultraschallfrequenzen oder überlagerten Audiosignalen eingebettet.

Durchführung

Verschiedene Codierungstechniken wurden getestet: frequenzmodulierte Signale, zeitlich komprimierte Befehle und Amplitudenmodulation ausserhalb des hörbaren Spektrums.

Ergebnisse

Amazon Alexa: Kurze Erkennung des Triggerwortes, aber automatischer Abbruch nach 2 Sekunden ohne vollständige Befehlsausführung.

Bixby, Google Assistant, Siri: Keine Reaktion auf versteckte Befehle. Moderne Filter erkennen und blockieren abnormale Audiocharakteristiken.

Fazit

> **Hidden Command Attack funktioniert nicht mehr:** Alle getesteten Systeme haben Schutzmechanismen implementiert, die versteckte Befehle erkennen und abblocken. Frühere Schwachstellen wurden geschlossen.

Historischer Kontext: Hidden Command Attacks waren 2017-2019 ein reales Problem. Die Hersteller haben seitdem aktiv Gegenmassnahmen entwickelt.

Replay Attack

Test aufgezeichneter Sprachbefehle

Replay Attacks prüfen, ob Sprachassistenten zwischen live gesprochenen und aufgezeichneten Befehlen unterscheiden können. Ein erfolgreicher Angriff würde bedeuten, dass Aufnahmen legitimer Befehle wiederverwendet werden können.

Aufnahmephase 1

Legitime Sprachbefehle wurden mit hochwertiger Aufnahmetechnik erfasst. Beispiele: "Wie ist das Wetter heute?", "Schalte das Licht ein", "Spiele Musik ab".

2 **Wiedergabephase**

Die aufgezeichneten Befehle wurden über Lautsprecher den Sprachassistenten vorgespielt, ohne dass eine Person live sprach.

Qualitätsstufen 3

Tests mit verschiedenen Aufnahmequalitäten: Studio-Qualität, Smartphone-Aufnahme, komprimierte Formate.

Ergebnisse

Alle Systeme betroffen

Amazon Alexa, Samsung Bixby, Google Assistant und Apple Siri führten alle aufgezeichnete Befehle aus, als wären sie live gesprochen.

Qualität entscheidend

Hochwertige Aufnahmen hatten nahezu 100% Erfolgsrate. Selbst Smartphone-Aufnahmen funktionierten in über 80% der Fälle.

Replay Attack ist weiterhin möglich: Dies stellt ein erhebliches Sicherheitsrisiko dar, insbesondere bei qualitativ hochwertigen Aufnahmen legitimer Nutzer.

Voice Cloning

Test synthetischer Stimmen

Voice Cloning nutzt KI-Technologie, um synthetische Stimmen zu generieren, die von echten Personen nicht zu unterscheiden sind. Diese Tests prüfen, ob Sprachassistenten geklonte Stimmen erkennen können.

Stimmenerfassung

Nur 20-30 Sekunden Audioaufnahme einer Zielperson waren erforderlich, um ein Voice-Cloning-Modell zu trainieren.

KI-Training

Tools wie Descript Overdub, Resemble.ai oder ElevenLabs wurden verwendet, um synthetische Stimmen zu generieren.

Befehlsgenerierung

Die geklonte Stimme wurde genutzt, um Befehle zu synthetisieren, die bei Voice-ID-geschützten Systemen getestet wurden.

Authentifizierungstest

Die synthetischen Befehle wurden den Sprachassistenten präsentiert, um zu prüfen, ob die Voice-ID umgangen werden kann.

Ergebnisse

20s	95%	4
Minimale Aufnahmezeit	**Erfolgsrate**	**Betroffene Systeme**
Ausreichend für hochqualitatives Voice Cloning	Voice-ID-Systeme wurden erfolgreich umgangen	Alexa, Bixby, Google Assistant und Siri

Voice Cloning stellt eine erhebliche Sicherheitslücke dar: Die Technologie ist einfach zugänglich, kostengünstig und hocheffektiv. Stimmbiometrie als alleiniger Authentifizierungsfaktor ist unzureichend.

Reale Bedrohung: 2019 wurde der CEO einer britischen Energiefirma durch eine geklonte Stimme um 243.000 Euro betrogen. Der Angreifer imitierte die Stimme des Konzernchefs.

HSLU

RFID, NFC
Technologie

HSLU

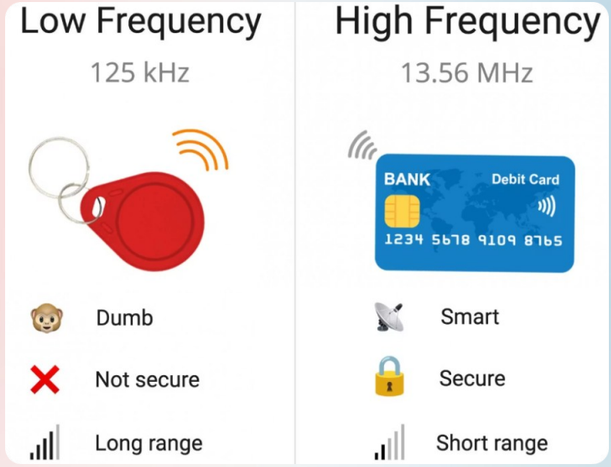
RFID Technologie VS NFC

NFC ist eine Unterkategorie von RFID (High Frequency, 13.56 MHz)

Frequenzbereiche im Vergleich

RFID: 125 kHz (Niedrigfrequenz) Kurzreichweite bis ca. 15 cm, einfache Protokolle, niedrige Sicherheit.
Tags senden ihre ID typischerweise ohne Authentifizierung.
Robuster bei Metall und Flüssigkeiten. Typische Anwendungen: Gebäudezugang, Parkplatzsysteme.

NFC: 13.56 MHz (Hochfrequenz) Kurzreichweite bis ca. 10 cm, komplexe Protokolle mit hoher Sicherheit.
Unterstützt fortgeschrittene Protokolle und Kryptographie (MIFARE, ISO 14443).
Verwendet in Bankkarten, öffentlichen Verkehrsmitteln. Bis zu 424 kbps



RFID Technologie im Detail

Quelle: blog.flipper.net

Die Abbildung zeigt den Aufbau eines typischen RFID-Systems mit den wesentlichen Komponenten: dem Lesegerät (Reader), der Antenne und dem passiven Tag. Die Energieübertragung erfolgt kontaktlos durch elektromagnetische Induktion.

Anatomie eines RFID Tags

Aufbau und Komponenten

Ein RFID-Tag besteht aus drei wesentlichen Elementen, die eng miteinander verbunden

- **Chip:** Enthält die gespeicherten Informationen über das physische Objekt. Der Chip verfügt über einen kleinen Speicher und eine Logikeinheit zur Verarbeitung von Befehlen.
- **Antenne:** Überträgt die Informationen mittels Funkwellen an ein Lesegerät. Die Antennengrösse bestimmt massgeblich die Reichweite des Tags.
- **Packaging:** Umhüllt den Chip und die Antenne, sodass das Etikett an physische Objekte angebracht werden kann. Das Material schützt vor Umwelteinflüssen.

Die Grösse und Form der Tags variiert stark je nach Anwendungsfall - von münzgrossen Chips bis zu dünnen, flexiblen Etiketten.





Bildquellen: IATA Baggage RFID Programme

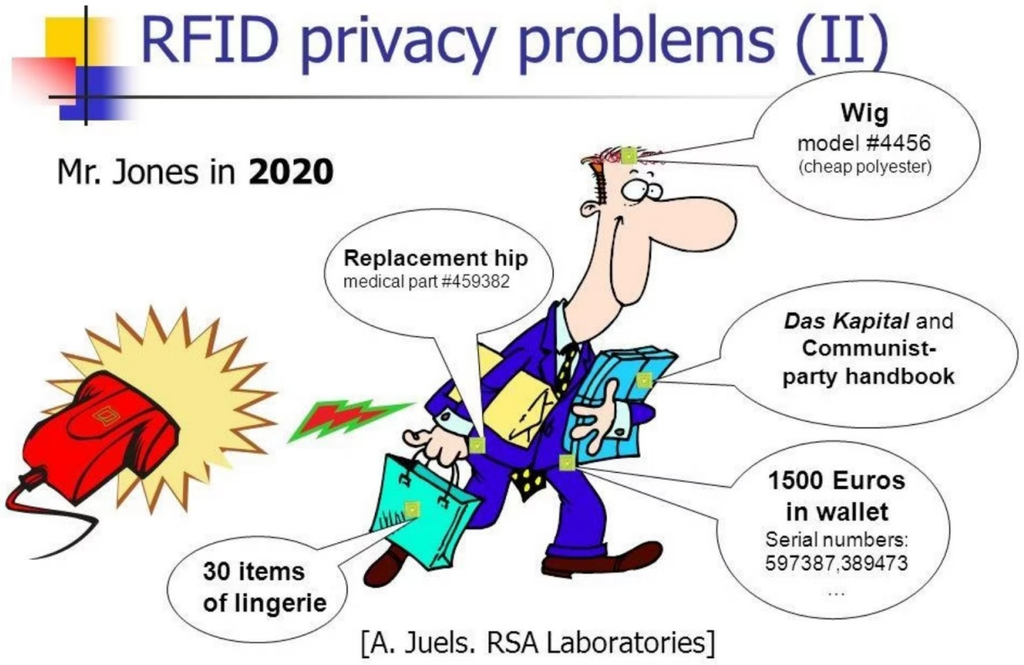
Datenschutzprobleme beim Verbraucherschutz

Kritische Herausforderungen

Sensible Daten auf Tags: RFID-Tags können persönliche und sensible Informationen speichern, die ohne Wissen des Besitzers ausgelesen werden können. Dies reicht von Einkaufsgewohnheiten bis zu Gesundheitsdaten.

Unbewusste Überwachung: Die meisten Benutzer nehmen ihre RFID-Tags nicht wahr und wissen nicht, wann diese ausgelesen werden. Die Technologie ist unsichtbar, die Datenerfassung erfolgt passiv und ohne aktive Zustimmung.

Standortverfolgung: Selbst wenn die Dateninhalte verschlüsselt sind, können Tags physisch verfolgt werden. Jeder Tag hat eine eindeutige ID, die zur Erstellung von Bewegungsprofilen genutzt werden kann. Dies verletzt die Privatsphäre des Standorts erheblich.



Bereits 2006 identifizierte Forschung von A. Juels die wesentlichen Sicherheits- und Privacy-Risiken von RFID-Technologie. Viele dieser Probleme sind bis heute relevant.

Quelle: RFID security and privacy: a research survey, IEEE Journal on Selected Areas in Communications, 2006

HSLU

RFID-Tracking: Eine Bedrohung für den Datenschutz

Die permanente, unsichtbare Datenerfassung ermöglicht eine detaillierte Überwachung, die weit über das hinausgeht, was viele Nutzer erwarten oder akzeptieren würden.

Unsichtbare Personenverfolgung

In (Kleidung, Eintrittskarten) integrierte RFID-Tags ermöglichen das stille Erfassen von Personenbewegungen in Echtzeit – oft ohne das Wissen oder die Zustimmung der Betroffenen.

Erstellung detaillierter Bewegungsprofile

Jede eindeutige RFID-ID kann kontinuierlich ausgelesen werden. Dies erlaubt die Erstellung umfassender Bewegungsprofile, die Aufschluss über Anwesenheit und Wege von Personen geben.

Verknüpfung mit Datenquellen

Durch die Kombination von RFID-Daten mit anderen Informationen (z.B. aus Loyalty-Karten, Online-Profilen) lassen sich extrem detaillierte Konsum- und Verhaltensmuster erstellen.

Kommerzielle Überwachung durch Einzelhändler

Im Einzelhandel dient RFID zu der Analyse des Kundenverhaltens – von der Verweildauer an Regalen bis zu Heatmaps der Ladenwege.



RFID-Sicherheitslücken

Die Einfachheit der RFID-Technologie, insbesondere in älteren Implementierungen, birgt erhebliche Sicherheitsrisiken, die oft übersehen werden. Diese Schwachstellen können von Angreifern mit relativ einfachen Mitteln ausgenutzt werden.

Schwache Verschlüsselung

Viele ältere RFID-Systeme verwenden keine oder nur rudimentäre Verschlüsselung. Dies ermöglicht es, Daten, die zwischen Tag und Lesegerät übertragen werden, einfach abzufangen und zu entschlüsseln.

Replay-Angriffe

Dabei wird eine legitim abgefangene Kommunikation aufgezeichnet und zu einem späteren Zeitpunkt wiederholt. So können beispielsweise Zugangsberechtigungen ohne den originalen Tag simuliert werden.

Klonen von Karten

Ein Angreifer kann die Identifikationsdaten eines RFID-Tags auslesen und auf einen leeren Tag kopieren. Dies führt zu einer Duplizierung der Karte, die dann für unautorisierten Zugang verwendet werden kann.

Funktioniert, wenn nur die UID (serial number) als Schutz geprüft ist.

Das Flipper Zero: Ein Werkzeug zur Demonstration

Das Flipper Zero ist ein tragbares Multi-Tool für Hacker und Sicherheitsexperten, das unter anderem RFID- und NFC-Funktionen unterstützt. Es kann diese Sicherheitslücken ausnutzen, um RFID-Signale zu lesen, zu emulieren und zu klonen.



Vulnerable Systeme und Anwendungen

- Alte Zugangskontrollsysteme in Bürogebäuden und Wohnanlagen
- Hotelkarten für Zimmerzugang
- Mitarbeiterausweise ohne moderne Verschlüsselungsmechanismen

Selbstschutz der Verbraucher

Technische Schutzmassnahmen gegen unerwünschtes RFID-Auslesen

Faraday Cage

Spezielle Hüllen aus leitfähigem Material blockieren elektromagnetische Felder vollständig. Erhältlich als Brieftaschen, Kartenhüllen oder Rucksäcke. Effektivste Schutzmethode gegen RFID-Auslesen.

RFID Sensor Detector

Kleine Geräte, die RFID-Leseversuche in der Nähe erkennen und den Benutzer warnen. Ermöglicht bewusste Reaktion auf Ausleseversuche. Nützlich zur Sensibilisierung.

Active Jamming

Blocker-Tags senden Störsignale aus, die legitime Lesegeräte blockieren. Kann auch als "Privacy Bit" implementiert werden. Rechtliche Situation in einigen Ländern unklar.

RFID Zapper

Gerät zur permanenten Zerstörung von RFID-Chips durch Hochspannungsimpulse. Nach dem "Zappen" ist der Chip dauerhaft unbrauchbar. Nur für eigene Tags geeignet, nicht für fremde!









NFC Modulationstechniken

Datenübertragung zwischen Karte und Lesegerät

Die Kommunikation zwischen NFC- oder RFID-Karten (wie Kreditkarten oder Bankkarten) und Lesegeräten nutzt spezielle Modulationsmethoden, um Daten zu übertragen:

ASK (Amplitude Shift Keying): Die Amplitude des Trägersignals wird moduliert, um Daten zu kodieren. Einfacher zu implementieren, aber anfälliger für Störungen. Wird bei einfachen RFID-Systemen verwendet.

PSK (Phase Shift Keying): Die Phase des Trägersignals wird zur Datenkodierung genutzt. Komplexer als ASK, aber robuster gegen Störungen und sicherer. Wird in Hochfrequenz- und NFC-Systemen (13,56 MHz) eingesetzt, besonders bei Kreditkarten und Bankkarten mit höheren Sicherheitsanforderungen.

Die Wahl der Modulationsmethode beeinflusst massgeblich die Reichweite, Datenrate und Sicherheit des Systems.

Card name/type	Read	Write	Save	Emulate
Mifare Classic	✅	✅	✅	✅
Mifare DESFire	✅			
Mifare Ultralight	✅		✅	✅
NTAG-21X	✅		✅	✅
EMV Cards			❌	❌
NFC-B				❌
iClass/PicoPass	✅	✅	✅	
EM4100/EM4102	✅	❌	✅	✅
H10301	✅	❌	✅	✅
Indala	✅	❌	✅	✅
T5577	✅	✅	✅	✅
EM4305	✅		✅	✅
Paxton Net2	❌	❌	❌	❌
Legic Prime	❌	❌	❌	❌

Visualisierung verschiedener Modulationstechniken

Wie funktionieren NFC-Zahlungen?

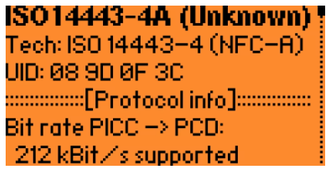


Ablauf einer NFC-Transaktion

1. **Aktivierung**
   Der NFC-Chip im Smartphone oder der Karte wird durch Näherung zum Terminal aktiviert
2. **Kommunikation**
   Aufbau einer verschlüsselten Verbindung zwischen Gerät und Terminal
3. **Datenübertragung**
   Tokenisierte Zahlungsdaten werden übermittelt (nicht die echte Kartennummer!)
4. **Authentifizierung**
   Dynamischer Authentifizierungscode wird generiert und validiert
5. **Autorisierung**
   Zahlungsabwickler prüft und genehmigt die Transaktion

Praktische Tests mit Flipper Zero

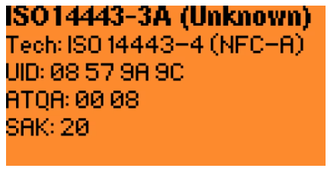
Zutrittskarte auslesen



Möglichkeiten: Mehr Informationen können gelesen werden, als auf der Karte sichtbar sind. Emulation oder Klonen ist theoretisch möglich.

Limitationen: Abhängig vom Kartentypus und Sicherheitsniveau. Moderne Karten mit Verschlüsselung bieten besseren Schutz.

E-Pass auslesen



Möglichkeiten: Nur begrenzte Daten können gelesen werden, grundlegende Informationen aus der MRZ-Zone.

Limitationen: Kein Zugriff auf PIN-geschützte Bereiche oder Sicherheitsdaten. Fingerabdrücke und sensible biometrische Daten sind durch EAC geschützt. Alle Daten sind verschlüsselt.

Remote Control Device



Fernbedienungen können aufgezeichnet und repliziert werden. Funktioniert bei älteren Rolling-Code-Systemen eingeschränkt.

Kreditkarten emulieren?



Wichtige Erkenntnis: Das Einzige, was ausgelesen werden kann, ist die Kreditkartennummer **im Klartext** - die reicht aber **nicht aus**, um eine Transaktion durchzuführen. CVV, dynamische Codes und weitere Sicherheitsmerkmale fehlen.

HSLU

Lab-Ergebnisse HS24

Erkenntnisse aus praktischen Versuchen

Erfolgreiche Angriffe

Auslesen erfolgreich

Lesen des MIFARE Classic 4K Zugangs-Badges ohne Probleme möglich

Emulation funktioniert

Emulierter Zugangs-Badge direkt über Flipper Zero erlaubte Zutritt zu Gebäude und in die Räumlichkeiten

Gescheiterte Angriffe

Klonen fehlgeschlagen

Klonen des 4K Badges auf MIFARE Classic 1K Karte war nicht möglich

UID nicht überschreibbar

Keine Möglichkeit, die eindeutige UID zu überschreiben

Speicherinkompatibilität

Nicht alle Daten vom 4K Badge passen auf die kleinere 1K Karte

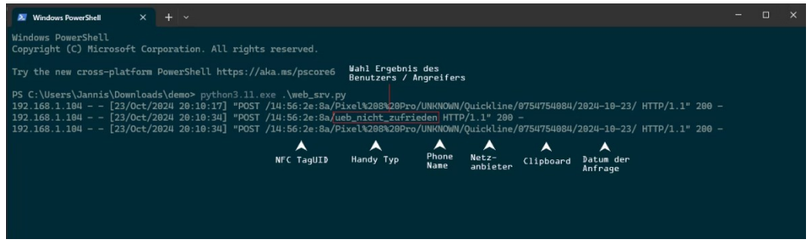
RFID-Experimente — Spoofing

RAW HEX	UID	Anpassung
FF:0F:00:E8:BD:00:01:00:00:10	756-09880001330**3**	Original
FF:0F:00:E8:BD:00:01:00:00:**11**	756-09880001330**3**	Leicht
FF:0F:00:**AA:BB**:00:01:00:00:10	885-090210078711	Mittel
FF:FF:FF:FF:FF:00:00:00:00:00	063-274877906943	Stark



Zentrale Erkenntnisse

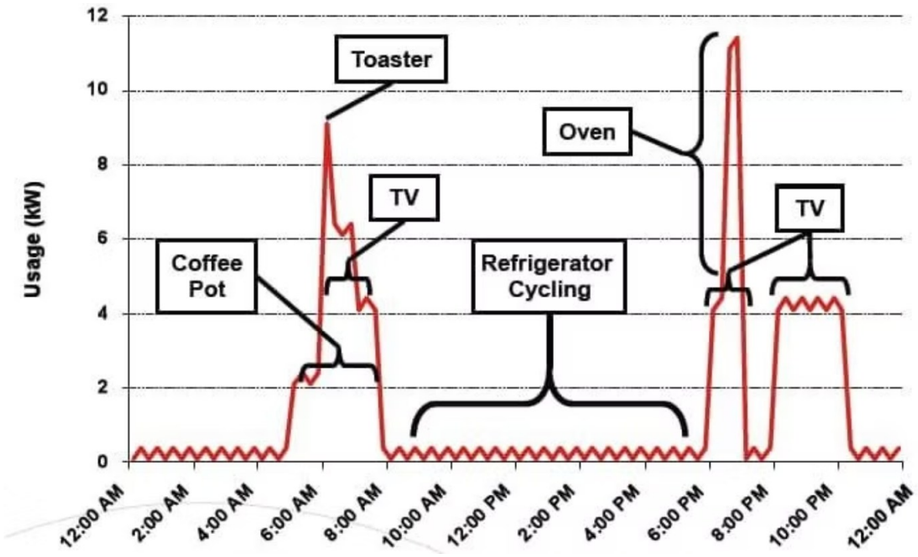
- NFC-Tags reagieren je nach Sicherheitsniveau sehr unterschiedlich auf Klonversuche
- Das Klonen ist technisch möglich, aber nicht bei allen Tag-Typen gleich einfach
- Ältere Tags wie MIFARE Classic-Serie weisen erhebliche Sicherheitslücken auf
- Moderne Tags wie MIFARE DESFire EV1 sind durch starke Verschlüsselung und gegenseitige Authentifizierung geschützt
- Emulation ist oft einfacher als physisches Klonen



Zitiert aus Gruppenarbeiten von René Krickhahn und Silvan Bärlocher

Smart Meters: Erstellung von Nutzungsprofilen

Was Ihr Stromverbrauch über Sie verrät



Die hochauflösenden Verbrauchsdaten von Smart Meters ermöglichen erschreckend präzise Rückschlüsse auf Ihr Privatleben:

Anwesenheitserkennung

Genaue Zeiten, wann jemand zu Hause ist oder das Haus verlässt. Urlaubszeiten und regelmässige Abwesenheiten werden sichtbar.

Aktivitätsmuster

Wann wird gekocht, geduscht, ferngesehen? Schlafens- und Aufstehzeiten sind erkennbar. Nächtliche Aktivitäten fallen auf.

Gerätenutzung

Verbrauchsspitzen verraten, welche Geräte genutzt werden. Unterschiedliche Geräte haben charakteristische "Fingerabdrücke" im Stromverbrauch.

Haushaltsgrösse

Anzahl der Bewohner lässt sich aus Verbrauchsmustern ableiten. Veränderungen (Nachwuchs, Auszug) werden sichtbar.

Diese Informationen sind für verschiedene Akteure interessant: Energieversorger, Werbeindustrie, Versicherungen, potenzielle Einbrecher oder Überwachungsbehörden. Der Schutz dieser Daten ist daher von höchster Bedeutung.

Quelle: Splunk Security Blog

Wasserzähler-Urteil des Bundesgerichts

Elektronische Wasserzähler und Datenschutz



Der Fall

Ein Schweizer Bundesgerichtsurteil befasste sich mit elektronischen Wasserzählern, die Daten per Funk übermitteln. Das Gericht stellte gravierende Datenschutzverletzungen fest.

Kernaussagen des Urteils

Fehlende Rechtsgrundlage: "Der Richter stellt fest, dass eine gesetzliche Grundlage für das Senden der Daten per Funk alle 30 Sekunden sowie für die Speicherung der Stundenwerte während 252 Tagen auf dem Gerät fehle."

Verstoss gegen Verhältnismässigkeit: Das Bundesgericht hält fest: «Die Datensicherheit allein vermag den Umstand, dass vorliegend mehr Personendaten bearbeitet werden als notwendig, nicht aufzuwiegen.»

Bedeutung für IoT-Geräte

- Auch wenn Daten verschlüsselt übertragen werden, muss die **Datenerhebung** verhältnismässig sein
- Es muss eine **klare Rechtsgrundlage** für die Erfassung und Speicherung von Daten existieren
- Die **Datenminimierung** ist ein zentrales Prinzip - nur notwendige Daten dürfen erhoben werden
- Lange Speicherfristen müssen begründet und verhältnismässig sein
- Der technische Schutz (Verschlüsselung) ersetzt nicht die rechtlichen Anforderungen

Dieses Urteil hat wegweisende Bedeutung für alle IoT-Geräte, die kontinuierlich Daten sammeln und übermitteln.

Quelle: Aargauer Zeitung

HSLU

E-Pass

E-Passports: RFID & Biometrie

Sicherheitstechnologie in Identitätskarten

Technische Grundlagen

Elektronische Pässe (E-Passports) basieren auf dem internationalen Standard ICAO Doc. 9303 (Oktober 2004) und nutzen fortgeschrittene RFID-Technologie kombiniert mit biometrischen Daten.

Gespeicherte Daten:

- Name des Inhabers, Geburtsdatum, Passnummer
- Gesichtserkennung
- Fingerabdrücke und Iris-Daten (optional)
- Digitales Foto mit hoher Auflösung
- Schreibbereich für zukünftige Anwendungen (z.B. digitale Visa)

Technische Spezifikationen:

- Basiert auf ISO 14443 Standard
- Passive RFID-Technologie (keine Batterie)
- Betriebsfrequenz: 13,56 MHz
- Vorgesehene Lesereichweite: 10 cm
- Tamper-Resistance: Physischer Schutz gegen Manipulation
- Integrierte Kryptographie für Datenschutz



Unterschied zu Supply Chain RFID

E-Passports verwenden deutlich fortgeschrittenere Technologie als einfache RFID-Tags in der Logistik:

- **Kürzere Reichweite:** 10 cm statt 5 Meter
- **Kryptographie:** Umfassende Verschlüsselung und Authentifizierung
- **Frequenz:** 13,56 MHz statt 915 MHz
- **Komplexere Protokolle:** Mehrschichtige Sicherheitsmechanismen

Council of the European Union - PRADO - CHE-AO-04001

Aufbau eines E-Passports





Quelle: BSI Deutschland

Maschinenlesbare Zone (MRZ)

Die optisch lesbare Zone am unteren Rand des Passes enthält:

- Ausweisart (P für Passport)
- Ausstellerland (3-Letter-Code)
- Name und Vorname
- Passnummer
- Nationalität
- Geburtsdatum
- Geschlecht
- Ablaufdatum
- Verschiedene Prüfziffern zur Validierung

RFID-Chip (zusätzlich)

Der eingebettete Chip speichert zusätzlich:

- **Biometrische Daten:** Hochauflösendes Gesichtsbild, optional Fingerabdrücke (2 Finger)
- **Digitale Signatur:** Zur Verifikation der Datenintegrität
- **Kryptographische Schlüssel:** Für Authentifizierung und Verschlüsselung
- **Schreibbereich:** Für zukünftige Anwendungen wie elektronische Visa

Kryptographische Schutzmechanismen

Mehrschichtige Sicherheit im E-Passport



Passive Authentication (PA)

Digitale Signatur des ausstellenden Landes über alle Daten. Stellt sicher, dass die Daten authentisch sind und nicht verändert wurden. **Wichtig:** PA authentifiziert nur die Daten, nicht den Container (Pass selbst).



Basic Access Control (BAC)

Optional, aber weit verbreitet. Symmetrische Schlüssel (KENC, KMAC) werden aus MRZ-Daten abgeleitet: Passnummer, Geburtsdatum, Ablaufdatum. Schützt vor unberechtigtem Auslesen, aber Schlüssel sind relativ kurz.



Active Authentication (AA)

Optional. Challenge-Response-Verfahren zur Authentifizierung des Chip-Inhalts. Public Key in signierten Daten, Private Key im Chip gespeichert. Dies ist ein "Anti-Cloning"-Feature.



Extended Access Control (EAC)

Optional. Zusätzlicher Schutz für hochsensible Daten (Fingerabdrücke). RSA-basierte Authentifizierung mit Zertifikaten. Leser muss sich mit privatem Schlüssel authentifizieren. Terminal-Zertifikat erforderlich.

Diese gestaffelten Sicherheitsmechanismen bieten unterschiedliche Schutzniveaus für verschiedene Datentypen im Pass. Nicht alle Mechanismen sind verpflichtend, aber moderne E-Pässe implementieren zunehmend alle Features.

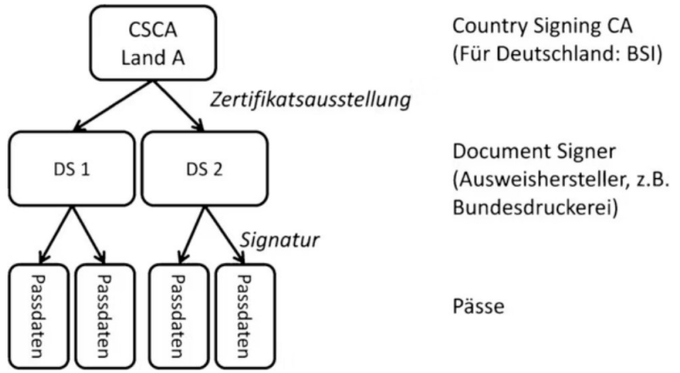
Passive Authentication im Detail

Funktionsweise

Ziel: Verhinderung von Änderungen an den im Pass gespeicherten Daten.

Implementierung: Bei der Herstellung wird eine digitale Signatur über alle gespeicherten Daten erstellt und im Chip gespeichert. Der Prozess:

1. Alle Datengruppen (DG1-DG16) werden gehasht
2. Diese Hashes werden im SOD (Document Security Object) gespeichert
3. Das SOD wird mit dem DS (Document Signer) Zertifikat des Ausstellerlandes unterzeichnet
4. Die Echtheit kann mit dem Country Signing Certificate (CSCA) überprüft werden



Schwachstellen in der Praxis

Lückenhafte Implementierung

Die Umsetzung an Flughäfen ist oft dürftig. Die Validierung der DS-Zertifikate wird an vielen Grenzübergängen einfach ausgelassen, was die Sicherheit massiv schwächt.

Kein Schutz gegen Klonen

PA verhindert **ausdrücklich nicht** das Klonen eines Passes. Es stellt nur sicher, dass die Daten authentisch sind, aber nicht, dass sie sich im Original-Chip befinden.

Vertrauenskette

Die Sicherheit hängt von der Integrität der gesamten Certificate Authority Infrastruktur ab. Kompromittierte CSCA-Schlüssel gefährden alle darauf basierenden Pässe.

Basic Access Control (BAC)

Zugriffskontrolle durch MRZ-Daten

Funktionsprinzip

BAC erfordert, dass das Lesegerät einen Schlüssel besitzt, der aus den Daten der maschinenlesbaren Zone (MRZ) generiert wird. Dies soll unbefugtes Auslesen verhindern.

Schlüsselableitung aus MRZ:

- Ausstellungsland (3 Zeichen)
- Art des Dokuments (1 Zeichen, z.B. "P" für Pass)
- Passnummer (bis zu 9 Zeichen)
- Nationalität (3 Zeichen)
- Geburtsdatum (YYMMDD, 6 Zeichen)
- Geschlecht (1 Zeichen)
- Ablaufdatum (YYMMDD, 6 Zeichen)
- Prüfziffern (3 Zeichen)

Sicherheitsprobleme

Schwache Entropie: Die für den Schlüssel verwendeten Daten sind leicht zu erraten. Viele Informationen sind auf dem Pass sichtbar oder können erraten werden:

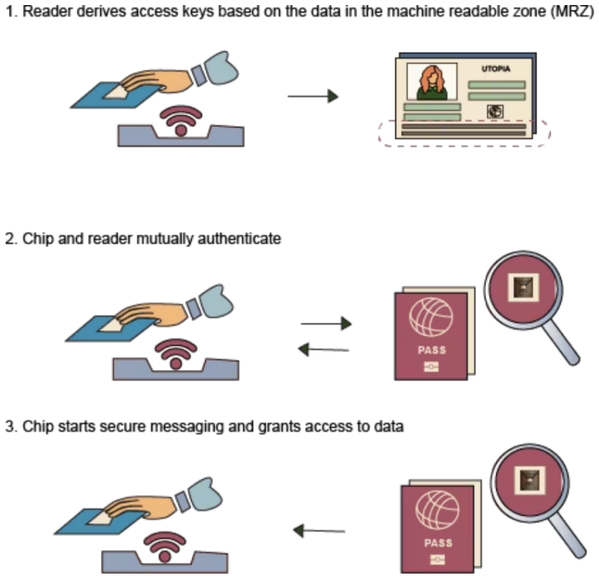
- Passnummern folgen oft vorhersehbaren Mustern
- Geburtsdatum hat nur ~30.000 mögliche Werte
- Ablaufdatum ist auf wenige Jahre beschränkt
- Geschlecht hat nur 2 Werte

Kurzer Schlüssel: Die resultierende Schlüssellänge ist zu kurz für moderne Sicherheitsanforderungen.

Brute-Force möglich: Forscher konnten zeigen, dass BAC in wenigen Stunden mit handelsüblicher Hardware überwunden werden kann. Bei bekannten Teilen der MRZ (z.B. Land, Geburtsjahr) reduziert sich der Suchraum dramatisch.

Wichtig: BAC bietet Grundschutz gegen gelegentliches Scannen, ist aber kein Schutz gegen gezielte Angriffe mit entsprechenden Ressourcen.

Extended Access Control (EAC)



Starker Schutz für sensible Daten

EAC wurde entwickelt, um hochsensible biometrische Daten zusätzlich zu schützen, insbesondere Fingerabdrücke und Iris-Scans.

Funktionsweise:

- Der Leser muss sich mit einem privaten RSA-Schlüssel authentifizieren
- Das öffentliche Gegenstück ist auf dem Pass gespeichert
- Challenge-Response-Verfahren
- Nur autorisierte Terminals mit gültigem Zertifikat erhalten Zugriff

Zertifikatsinfrastruktur: Zum Auslesen der Fingerabdrücke wird ein spezielles Auslesezertifikat benötigt. Diese Zertifikate werden nur an vertrauenswürdige Behörden ausgegeben.

Mehrschichtiger Schutz

1 Terminal muss IS-Privatschlüssel besitzen	2
Chip-Authentifizierung Pass überprüft Lesegerät	**Terminal-Authentifizierung** Zertifikatsprüfung
3	4
Secure Messaging Verschlüsselte Kommunikation	**Zugriff gewährt** Fingerabdrücke lesbar

Datenschutz bei Fingerabdrücken

Schweizer Berechtigungskonzept

Strenge Zugangskontrolle

Zum Auslesen der Fingerabdrücke aus Schweizer E-Pässen ist ein spezielles Auslesezertifikat erforderlich. Dieses unterliegt strengen Vergabekriterien.

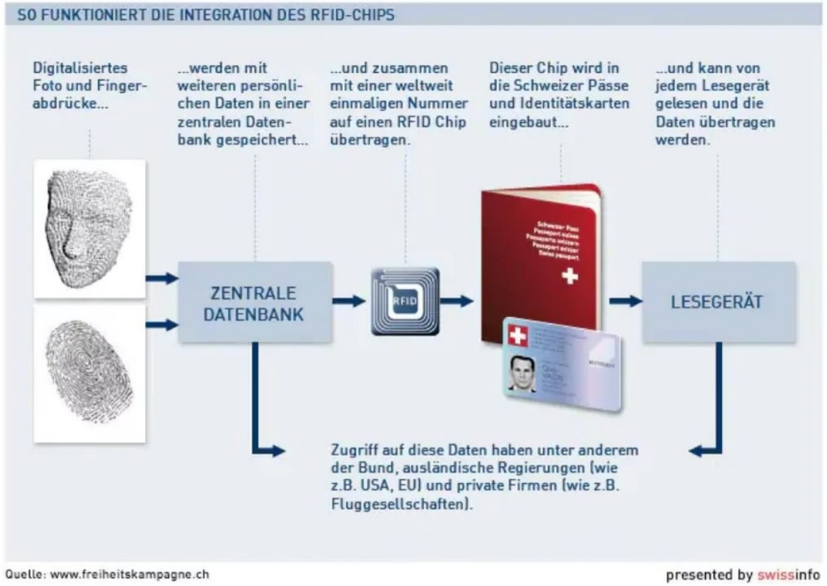
Offizielle Erklärung des Bundes:

> "Die Fingerabdrücke sind besonders gesichert: Damit ein anderes Land die Fingerabdrücke überhaupt lesen kann, muss es über die Berechtigung der Schweiz verfügen. Das Departement erteilt diese nur jenen Ländern, deren Datenschutzniveau dem schweizerischen gleichwertig ist."

Das Departement kann die Berechtigung auch anderen Stellen (z.B.

Fluggesellschaften) erteilen, die im öffentlichen Interesse die Identität von

Personen überprüfen müssen.



Kritische Fragen

- Wie wird "gleichwertiges Datenschutzniveau" in der Praxis überprüft?
- Welche Länder haben aktuell Zugriff auf Schweizer Fingerabdrücke?
- Wie wird die Einhaltung der Datenschutzstandards kontinuierlich überwacht?
- Was passiert mit den Daten nach dem Auslesen in anderen Ländern?
- Gibt es eine zentrale Liste autorisierter Lesegeräte?

Quellen: Thurgauer Passbüro, SwissInfo

Können alle Länder die Fingerabdrücke eines Schweizer ePasses auslesen?

Warum erhalten nicht alle Länder Zugriff auf Fingerabdrücke?

Vergleich der Authentifizierungsmethoden

Schutzniveaus im E-Passport

Passive Authentication (PA)	✗	✓	✗	✗	Obligatorisch
Basic Access Control (BAC)	✓ (eingeschränkt)	✓	✗	✗	Optional (weit verbreitet)
Active Authentication (AA)	-	✓	✓	✗	Optional (zunehmend)
Extended Access Control (EAC)	✓ (stark)	✓	✓	✓	Optional (für sensible Daten)
PA + BAC	✓ (mittel)	✓	✗	✗	Häufige Kombination
PA + BAC + AA	✓ (mittel)	✓	✓	✗	Empfohlen

CE (Password Authenticated Connection Establishment)

PACE (Password Authenticated Connection Establishment) Nachfolger von BAC, ersetzt SHA-1-basierte MRZ-Schlüssel; in Deutschland, Österreich, Frankreich seit 2010+ implementiert

Moderne E-Pässe sollten idealerweise alle vier Schutzmechanismen implementieren, um maximale Sicherheit für alle gespeicherten Daten zu gewährleisten. Der Schweizer Pass 11 **erfüllt** diese Anforderung.

Schweizer e-Pass: Sicherheitsstatus-Analyse

Eine detaillierte Bewertung der aktuellen Schweizer ePassport-Implementierung im internationalen Vergleich zeigt signifikante Sicherheitsdefizite. Der Pass 10 verlässt sich ausschliesslich auf BAC ohne moderne Schutzmechanismen.

BAC (Basic Access Control)

Status: Implementiert – Standard

Ab Pass 10 (2018) wird PACE zusätzlich implementiert. BAC bleibt als Rückwärtskompatibilität erhalten

Moderne Schweizer ePässe nutzen PACE und sind dadurch weitgehend gegen die bekannten Schwachstellen von BAC geschützt. Ältere Pässe ohne PACE bleiben hingegen anfällig.
Ab 2018

Extended Access Control (EAC)

Status: Implementiert – Gut

EAC schützt biometrische Daten (Fingerabdrücke) vor unbefugtem Zugriff. Nur autorisierte Terminals können auf diese sensiblen Informationen zugreifen.

Internationale Vergleichstabelle

Land	Pass-Generation	PACE eingeführt	BAC-Status	Status
Deutschland	ePA 2010	2010 (BSI TR-03110)	Fallback	✓ Geschützt
Niederlande	Nederlands Paspoort	≤ 2014 (EU-Pflicht)	Fallback	✓ Geschützt
Schweiz Pass 10 (2010–2022)	Pass 10	Nicht implementiert	Einziger Schutz!	✗ Nur BAC
Schweiz Pass 22 (ab Okt. 2022)	Pass 22	Ab Oktober 2022	Fallback	✓ Geschützt

HSLU

Hochschule Luzern

Informatik

Dr. Radwan Eskhita